



Rafforzamento della Sicurezza Infrastrutturale

nella Piattaforma
E-Commerce



Fabio Renna

Venezia • 20 febbraio 2026

EPICODE - Institute of Technology

Indice

1. Executive Summary
2. Contesto e architettura attuale
3. Analisi delle minacce e modello di rischio
4. Misure preventive contro SQLi e XSS
5. Impatto economico di un attacco DDoS
6. Incident Response Plan in caso di compromissione della DMZ
7. Architettura di Sicurezza Proposta
8. Piano di Investimento
9. Approccio Integrato alla Sicurezza e Continuità Operativa
10. Evoluzione della Maturità di Sicurezza
11. Equilibrio tra Sicurezza ed Operatività
12. Visione Prospettica
13. Conclusione

1. Executive Summary

Questo documento analizza la sicurezza di un'infrastruttura e-commerce esposta su Internet e propone un modello di rafforzamento progettato secondo un approccio basato sul rischio

L'obiettivo non è massimizzare la complessità difensiva, ma progettare un sistema resiliente, proporzionato al rischio e sostenibile nel tempo.

Le minacce considerate sono principalmente

- SQL Injection
- Cross-Site Scripting
- Distributed Denial of Service
- Compromissione malware del server in DMZ

La proposta finale integra prevenzione, rilevamento e capacità di risposta, mantenendo il budget entro i 30-40 mila euro e garantendo continuità operativa.

2. Contesto e Architettura Attuale

L'architettura attuale prevede un server e-commerce collocato in DMZ

La DMZ, Demilitarized Zone, è una zona di rete isolata che ospita sistemi esposti verso Internet, con l'obiettivo di separare tali sistemi dalla rete interna

Attualmente la DMZ può comunicare con la rete interna tramite policy firewall

Il rischio principale è che, in caso di compromissione del server pubblico, un attaccante possa tentare un movimento laterale verso sistemi interni più critici

Manca inoltre un sistema centralizzato di monitoraggio degli eventi di sicurezza



3. Analisi delle minacce e modello di rischio.

Le principali minacce applicative sono riconducibili a vulnerabilità incluse nella OWASP Top 10

OWASP, Open Web Application Security Project, è uno standard internazionale di riferimento per la sicurezza delle applicazioni web.

SQL Injection

La SQL Injection è un attacco che sfrutta una gestione non sicura delle query verso il database. Un attaccante può inserire codice SQL malevolo nei campi di input, manipolando le interrogazioni e ottenendo accesso ai dati.

Le conseguenze possono includere accesso non autorizzato, modifica o cancellazione di dati e data breach.

Cross-Site Scripting

Il Cross-Site Scripting consente l'iniezione di codice JavaScript malevolo eseguito nel browser degli utenti.

Può portare al furto di sessioni, al dirottamento degli account e alla compromissione della fiducia nel brand.

DDoS

Un attacco Distributed Denial of Service consiste nel saturare le risorse del server tramite traffico massivo, rendendo il servizio indisponibile.

Malware Infection

In caso di compromissione del server in DMZ, il rischio principale è la propagazione verso la rete interna e l'esfiltrazione di dati.

4. Misure preventive contro SQLi e XSS

Le misure adottate seguono il principio della difesa multilivello.

Livello applicativo

Vengono implementate

- **Input Validation**, ovvero validazione rigorosa dei dati inseriti
- **Prepared Statements**, query precompilate che impediscono l'iniezione di codice SQL
- **ORM**, Object Relational Mapping, che riduce l'interazione diretta con query SQL manuali
- **Output Encoding**, codifica dell'output per impedire l'esecuzione di script malevoli
- **CSP**, Content Security Policy, che limita gli script eseguibili nel browser

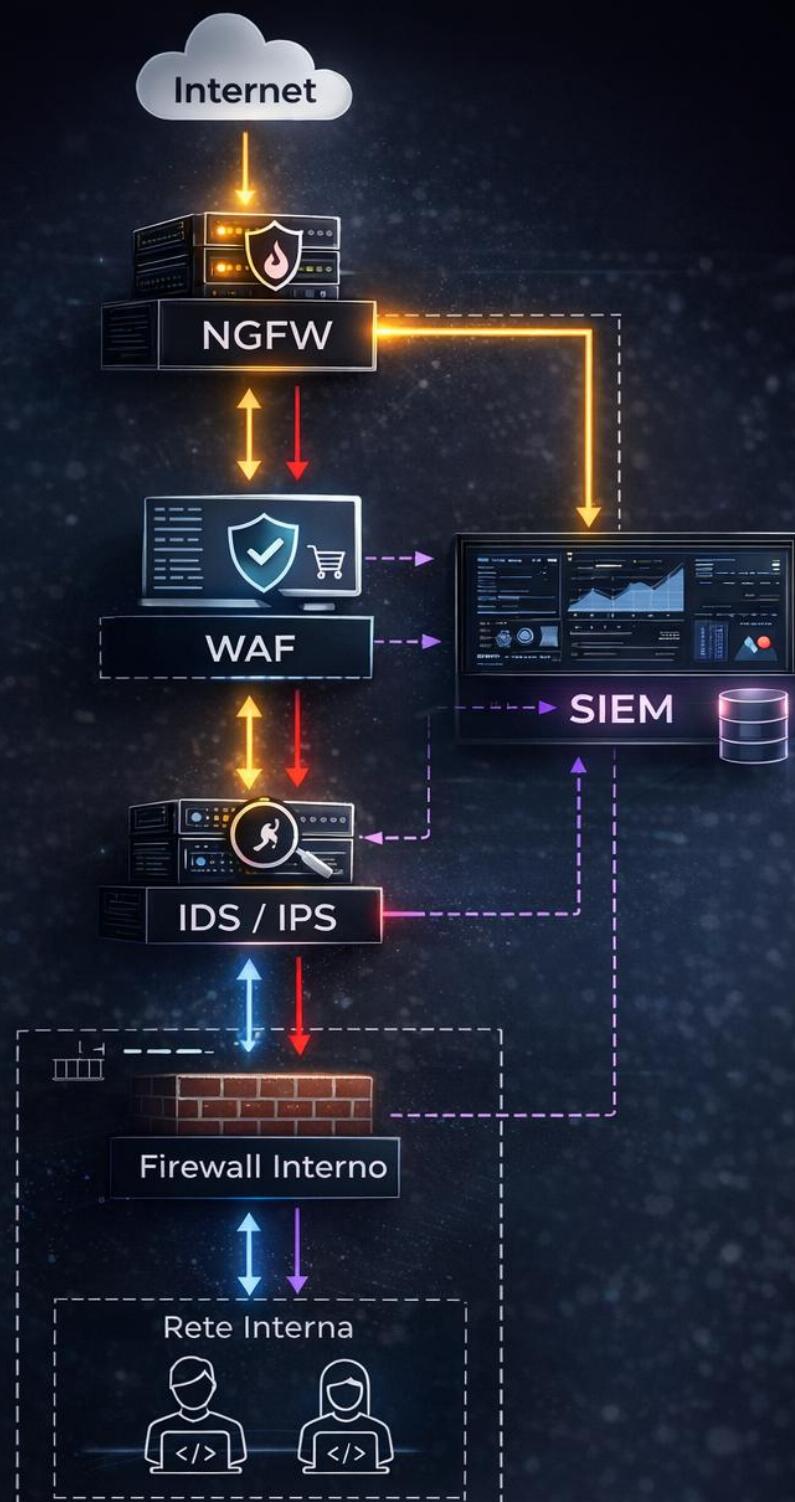
Livello infrastrutturale

Viene introdotto un **WAF**, Web Application Firewall, posizionato davanti al server e-commerce. Il WAF analizza il traffico HTTP e HTTPS e blocca richieste sospette a livello applicativo.

A livello perimetrale viene implementato un **NGFW**, Next Generation Firewall, capace di Deep Packet Inspection, cioè analisi approfondita del traffico.

Si introduce inoltre un sistema **IDS o IPS**, Intrusion Detection / Intrusion Prevention System, per il monitoraggio del traffico tra DMZ e rete interna.

Tutti i log vengono centralizzati in un **SIEM**, Security Information and Event Management, piattaforma che raccoglie, correla e analizza eventi di sicurezza.



- ➡ Traffico Utente
- ➡ Traffico Malevolo
- ➡ Traffico Interno
- - - ➡ Log

5. Impatto economico di un attacco DDoS

Il servizio genera una perdita stimata di **1.500 euro** al minuto in caso di indisponibilità

Un attacco DDoS della durata di **10 minuti** comporterebbe quindi una perdita diretta di 15.000 euro.

A questa cifra vanno aggiunti danni indiretti come perdita di fiducia dei clienti, possibile riduzione del traffico futuro e costi di recovery.

Una stima realistica porta l'impatto complessivo a circa **20.000-25.000 euro** per singolo evento

Per mitigare questo rischio viene proposta l'adozione di una CDN, Content Delivery Network, che distribuisce il traffico su più nodi e assorbe eventuali picchi.

Viene inoltre previsto un servizio di protezione Anti-DDoS a livello Layer 7.

Il tutto integrato in un BCP, Business Continuity Plan, piano che definisce le procedure per garantire continuità operativa, e in un DRP, Disaster Recovery Plan, piano di ripristino dell'infrastruttura in caso di incidente grave.

6. Incident Response Plan – Compromissione della DMZ

In caso di compromissione del server e-commerce l'obiettivo prioritario è evitare la propagazione verso la rete interna e preservare l'integrità dei dati aziendali.

L'Incident Response Plan, IRP, prevede quattro fasi:

1) Containment

Isolamento immediato del server compromesso e blocco del traffico verso la rete interna.

2) Identificazione degli IOC

Gli IOC, Indicator of Compromise, sono elementi tecnici che indicano una compromissione. Possono includere indirizzi IP sospetti, hash di file malevoli, domini Command and Control, cioè server remoti utilizzati dall'attaccante.

3) Analisi tramite SIEM

Correlazione degli eventi per individuare eventuali tentativi di movimento laterale o esfiltrazione dati.

4) Hardening post-incidente

Aggiornamento patch, revisione policy firewall e rafforzamento delle misure di controllo.



7. Architettura di Sicurezza Proposta

L'architettura di sicurezza proposta integra le contromisure applicative e infrastrutturali in un modello coerente di difesa multilivello.

La struttura finale si sviluppa secondo una logica a strati, riducendo la superficie di attacco e introducendo capacità di monitoraggio e contenimento.

La catena di protezione risulta così organizzata:

Internet



CDN con protezione Anti-DDoS



NGFW (Next Generation Firewall) per filtraggio perimetrale e controllo del traffico Layer 3–7



WAF (Web Application Firewall) per protezione applicativa contro SQL Injection e XSS



DMZ contenente il server e-commerce



IDS/IPS per il monitoraggio del traffico tra DMZ e rete interna



Firewall interno con policy restrittive



Rete interna segmentata

Parallelamente, tutti i dispositivi critici inviano i log al SIEM (Security Information and Event Management), che consente la correlazione degli eventi e la generazione di alert in tempo reale.

Questa architettura consente di:

- intercettare minacce a livello perimetrale
- bloccare attacchi applicativi prima che raggiungano il server
- rilevare eventuali tentativi di movimento laterale
- centralizzare il monitoraggio degli eventi di sicurezza
- attivare tempestivamente le procedure previste dall'Incident Response Plan

Il modello non si limita alla prevenzione, ma integra rilevamento e risposta, trasformando l'infrastruttura da passiva a proattivamente monitorata.

8. Piano di Investimento

L'obiettivo del presente piano di investimento non è massimizzare il livello teorico di sicurezza, bensì raggiungere un equilibrio concreto tra protezione, continuità operativa e sostenibilità economica. Le stime riportate fanno riferimento a un'infrastruttura e-commerce di dimensioni medio-piccole, con:

- 1 dominio principale
- traffico web non enterprise-scale
- logging selettivo (firewall, WAF, IDS/IPS, server DMZ)
- nessun SOC 24/7 esternalizzato

I costi includono, ove specificato, hardware, licenze annuali e attività di configurazione iniziale.

8.1 Struttura dei Costi

L'investimento si suddivide in:

- **CapEx (Capital Expenditure)** → acquisto hardware
- **OpEx (Operational Expenditure)** → licenze, canoni annuali, servizi cloud
- **Servizi professionali** → configurazione, tuning e hardening iniziale

8.2 Componenti Infrastrutturali

NGFW – Next Generation Firewall

Firewall perimetrale con funzionalità di Deep Packet Inspection (analisi approfondita del traffico), IPS integrato e controllo applicativo.

Stima realistica:

- Hardware appliance SMB/medium: 2.000 – 4.000 €
- Licenze security bundle + supporto 1 anno: 3.000 – 5.000 €

Totale stimato: 5.000 – 8.000 €

Questa soluzione evita appliance sovradimensionate mantenendo adeguata protezione Layer 3–7.

WAF + CDN – Web Application Firewall (Cloud)

Protezione specifica contro attacchi applicativi (SQLi, XSS, bot malevoli) e mitigazione DDoS di livello medio.

Soluzione cloud (es. piano business CDN con WAF integrato).

Stima:

- Canone annuale: 2.500 – 5.000 €
- Configurazione e tuning iniziale: 1.000 – 2.000 €

Totale stimato primo anno: 3.500 – 7.000 €

Scelta coerente con il principio di non appesantire l'infrastruttura con appliance dedicate.

IDS / IPS – Intrusion Detection / Prevention System

Sistema di monitoraggio tra DMZ e rete interna per intercettare tentativi di lateral movement.

Opzione consigliata:

- Modulo IPS integrato nel NGFW

oppure

- Soluzione open source (es. Suricata) su VM dedicata

Stima:

- Setup e tuning regole: 2.000 – 4.000 €

8.3 SIEM – Security Information and Event Management

Il SIEM rappresenta il cuore del monitoraggio e consente la correlazione eventi e la generazione di alert.

Vengono valutate due opzioni.

Opzione A – SIEM Open Source (es. Wazuh)

Soluzione senza costi di licenza ma con investimento in:

- VM dedicata
- Configurazione use case
- Creazione dashboard
- Definizione regole di correlazione

Stima:

- Setup e tuning iniziale: 6.000 – 10.000 €
- Costi infrastrutturali (VM/cloud): 1.000 – 2.000 € annui

Totale primo anno: 7.000 – 12.000 €

Vantaggi:

- Costi controllati
- Nessuna dipendenza forte da vendor
- Maggiore flessibilità

Opzione B – SIEM Cloud (es. Microsoft Sentinel)

Modello pay-as-you-go basato su volume di log ingeriti.

Stima con logging selettivo:

- 4.000 – 8.000 € annui
- Setup iniziale e use case: 3.000 – 5.000 €

Totale primo anno: 7.000 – 13.000 €

Vantaggi:

- Scalabilità immediata
- Integrazione cloud nativa
- Minore gestione infrastrutturale interna

8.4 Servizi Professionali e Hardening

Include:

- Revisione policy firewall
- Configurazione regole WAF
- Definizione Incident Response workflow
- Testing e validazione

Stima:

4.000 – 6.000 €

8.5 Sintesi Economica

Scenario equilibrato (NGFW + WAF cloud + IPS + SIEM open source):

- NGFW: 6.000 €
- WAF/CDN: 5.000 €
- IDS/IPS: 3.000 €
- SIEM (Open Source): 9.000 €
- Servizi e hardening: 5.000 €

Totale stimato primo anno: circa 28.000 – 32.000 €

Scenario con SIEM cloud:

Totale stimato primo anno: circa 32.000 – 38.000 €

Entrambi rientrano nel budget massimo di 30–40 mila euro indicato.

8.6 Giustificazione dell'Investimento

Un singolo attacco DDoS da 10 minuti può generare una perdita diretta di 15.000 €, con impatto complessivo stimato fino a 25.000 € considerando danni reputazionali.

Un data breach applicativo può comportare:

- perdita clienti
- sanzioni normative
- costi di notifica
- danni reputazionali difficilmente quantificabili

L'investimento proposto riduce significativamente:

- superficie d'attacco
- probabilità di movimento laterale
- tempo medio di rilevamento (MTTD – Mean Time To Detect)
- tempo medio di risposta (MTTR – Mean Time To Respond)

Il rapporto rischio/investimento risulta pertanto coerente e sostenibile.

9. Approccio Integrato alla Sicurezza e Continuità Operativa

L'analisi condotta non si è limitata all'introduzione di singoli strumenti di sicurezza, ma ha seguito un approccio strutturato basato sul rischio e sulla continuità operativa.

L'architettura iniziale presentava una criticità strutturale evidente: la possibilità che un'eventuale compromissione del server in DMZ potesse evolvere in movimento laterale verso la rete interna. In un contesto e-commerce questo rischio non è solo tecnico, ma direttamente collegato alla continuità del business e alla fiducia dei clienti.

La soluzione proposta introduce una difesa multilivello (Defense in Depth), integrando:

- protezione perimetrale tramite NGFW
- protezione applicativa tramite WAF
- monitoraggio interno tramite IDS/IPS
- centralizzazione e correlazione eventi tramite SIEM
- segmentazione controllata tra DMZ e rete interna

L'elemento distintivo del modello non è la presenza dei singoli strumenti, ma la loro integrazione coerente in un processo di prevenzione, rilevamento e risposta.

10. Evoluzione della Maturità di Sicurezza

L'introduzione del SIEM consente di misurare e migliorare progressivamente due indicatori fondamentali:

- **MTTD (Mean Time To Detect)** – tempo medio di rilevamento di un incidente
- **MTTR (Mean Time To Respond)** – tempo medio di risposta e contenimento

Senza monitoraggio centralizzato questi parametri risultano non misurabili. Con l'architettura proposta diventano KPI (Key Performance Indicator) osservabili e migliorabili nel tempo.

Questo rappresenta il passaggio da una sicurezza reattiva a una sicurezza misurabile e governabile.

11. Equilibrio tra Sicurezza e Operatività

Un aspetto fondamentale del progetto è stato evitare un over-engineering dell'infrastruttura. Non sono state introdotte soluzioni eccessivamente complesse o sovradimensionate, come:

- micro-segmentazione avanzata su ogni asset
- SOC esternalizzato 24/7
- sistemi EDR enterprise su tutta la rete

Le scelte effettuate rispettano il principio di proporzionalità al rischio, mantenendo:

- bassa latenza applicativa
- semplicità gestionale
- costi sostenibili
- possibilità di scalabilità futura

La sicurezza è stata progettata come fattore abilitante del business, non come ostacolo operativo.

12. Visione Prospettica

L'architettura proposta rappresenta una base solida e scalabile.

In caso di crescita del traffico o aumento della complessità infrastrutturale sarà possibile:

- espandere le capacità del SIEM
- introdurre automazione tramite SOAR (Security Orchestration, Automation and Response)
- integrare feed di Threat Intelligence per aggiornamento dinamico degli IOC
- implementare strategie Zero Trust

Il modello attuale è quindi progettato per evolvere, non per rimanere statico.

13. Conclusione

La soluzione definita garantisce:

- riduzione della superficie d'attacco
- contenimento efficace in caso di compromissione
- capacità di monitoraggio continuo
- sostenibilità economica
- equilibrio tra sicurezza e performance

L'infrastruttura passa da una condizione di esposizione potenzialmente critica a un modello resiliente, monitorato e controllato.

La sicurezza, in questo modello, non è una barriera tecnologica, ma un processo continuo di gestione del rischio orientato alla protezione del valore aziendale.

Venezia, 20/02/2026

Fabio Renna